

The Phone Boss ULTD — Statement of Applicability Summary

ISO/IEC 27001:2022 Annex A starter assessment. This portfolio artifact covers 10 priority controls and is not a complete certification Statement of Applicability.

Coverage	
Measure	Result
Priority controls assessed	10
Annex A reference controls	93
Starter coverage	10.8%
Applicable controls	10

Implementation status	
Status	Count
Implemented — evidence pending	1
Partially implemented	9
Planned	0

Control overview				
Control	Theme	Title	Status	Related risks
A.5.9	Organizational	Inventory of information and other associated assets	Partially implemented	R-01, R-02, R-03, R-04, R-08
A.5.15	Organizational	Access control	Partially implemented	R-02, R-04, R-06
A.5.19	Organizational	Information security in supplier relationships	Partially implemented	R-08, R-09
A.5.24	Organizational	Information security incident management planning and preparation	Partially implemented	R-07
A.5.30	Organizational	ICT readiness for business continuity	Partially implemented	R-03, R-05, R-08
A.5.34	Organizational	Privacy and protection of personally identifiable information	Partially implemented	R-01, R-06, R-07, R-09
A.7.9	Physical	Security of assets off-premises	Partially implemented	R-01
A.8.1	Technological	User endpoint devices	Implemented — evidence pending	R-04
A.8.5	Technological	Secure authentication	Partially implemented	R-02
A.8.13	Technological	Information backup	Partially implemented	R-05, R-08

Portfolio interpretation
All 10 selected controls are applicable to the current business and risk environment.
One endpoint control is implemented based on stated practices, with evidence collection still pending.
Nine controls are partially implemented and have defined improvement actions.
No control is marked fully verified because supporting evidence must still be assembled and reviewed.
The full certification SoA would address all 93 Annex A reference controls, including justified exclusions.
This starter demonstrates risk-based control selection, traceability, and evidence planning without claiming certification.

Basis of selection: the current risk register, business requirements, customer-information handling, supplier dependencies, and continuity needs.											
Control	Theme	Control title	Applicable?	Selection basis	Justification	Implementation status	Current implementation	Gap / planned improvement	Expected evidence	Owner	Related risk IDs
A.5.9	Organizational	Inventory of information and other associated assets	Yes	Risk treatment and operational need	The business must identify customer devices, business equipment, information, accounts, applications, cloud services, website assets, and responsible owners.	Partially implemented	Customer devices and repairs are recorded through digital and physical receipts.	Create a consolidated inventory covering customer devices in custody, business devices, critical accounts, cloud services, websites, domains, ownership, location, purpose, and status.	Asset register; repair-device log; critical-account list; cloud-service inventory; review record	Richard Vincent	R-01, R-02, R-03, R-04, R-08
A.5.15	Organizational	Access control	Yes	Risk treatment and business requirement	Access to customer devices, business information, payments, email, websites, and administrative accounts must be restricted according to business need.	Partially implemented	The owner is the sole authorized operator; business accounts and devices use authentication controls.	Document access-control rules, maintain an account inventory, conduct periodic reviews, and establish approval and removal steps before adding workers or contractors.	Access-control policy; account inventory; access-review record; account settings; onboarding and offboarding records	Richard Vincent	R-02, R-04, R-06
A.5.19	Organizational	Information security in supplier relationships	Yes	Supplier dependency and risk treatment	External providers support email, payments, website availability, source files, domains, and business records.	Partially implemented	Established providers are used; MFA protects critical accounts; Stripe processes full card data without the business storing complete card numbers.	Create a supplier register and document data access, dependency, security expectations, review frequency, recovery, and exit arrangements.	Supplier register; agreements; provider security information; MFA evidence; supplier reviews; insurance documentation	Richard Vincent	R-08, R-09
A.5.24	Organizational	Information security incident management planning and preparation	Yes	Risk treatment and customer obligation	Security incidents could affect customer devices, customer information, business accounts, payments, and online services.	Partially implemented	The owner is the incident decision-maker; MFA, customer-device procedures, passcode handling, and restorable records provide limited capability.	Document and test an incident-response procedure covering identification, containment, evidence preservation, communication, recovery, and lessons learned.	Incident-response procedure; incident log; notification contacts; communication templates; tabletop results	Richard Vincent	R-07
A.5.30	Organizational	ICT readiness for business continuity	Yes	Availability risk treatment	The business depends on cloud services, electronic records, online services, payment systems, and access controlled by one owner.	Partially implemented	Business records have been restored successfully; website and repository files are available; alternative communication and payment methods exist.	Document continuity arrangements for owner unavailability, provider outages, website disruption, restoration, and customer communication; complete recovery testing.	Restoration record; continuity plan; recovery instructions; emergency contacts; website test; continuity exercise	Richard Vincent	R-03, R-05, R-08
A.5.34	Organizational	Privacy and protection of personally identifiable information	Yes	Privacy obligation and risk treatment	The business processes customer identity, contact, device, repair, receipt, temporary passcode, and limited payment information.	Partially implemented	Access is limited to the owner; temporary paper passcodes are destroyed after testing; full card numbers are not stored; records are backed up.	Document privacy, retention, secure deletion, customer-request, and suspected-breach procedures.	Privacy notice; information inventory; retention schedule; deletion records; passcode-destruction confirmation; incident records	Richard Vincent	R-01, R-06, R-07, R-09
A.7.9	Physical	Security of assets off-premises	Yes	Custody and physical-security risk treatment	Customer devices and business equipment are transported, repaired at customer locations, or stored temporarily at the home workspace.	Partially implemented	Devices remain under the owner's control; most are returned the same day; overnight devices are stored securely.	Document transportation, custody, overnight storage, loss reporting, and return procedures; consistently retain custody evidence.	Customer intake form; custody record; overnight-device log; return confirmation; storage-control evidence	Richard Vincent	R-01
A.8.1	Technological	User endpoint devices	Yes	Endpoint and information-access risk treatment	Endpoint devices provide access to customer information, business records, communications, websites, and critical accounts.	Implemented — evidence pending	Devices use passwords, PINs or biometrics, encryption, automatic updates, endpoint protection, MFA, backups, and remote lock or wipe.	Collect operating evidence and migrate business activity to dedicated secured devices as an improvement.	Device inventory; encryption status; update status; endpoint-protection status; lock and remote-wipe settings; backup evidence	Richard Vincent	R-04
A.8.5	Technological	Secure authentication	Yes	Unauthorized-access risk treatment	Critical accounts provide access to communications, payments, websites, source files, domains, and business records.	Partially implemented	MFA is enabled across critical business accounts.	Verify password uniqueness, recovery methods, active sessions, connected integrations, and available phishing-resistant authentication.	MFA configuration; password-manager review; recovery settings; active-session review; integration inventory	Richard Vincent	R-02
A.8.13	Technological	Information backup	Yes	Availability and recovery risk treatment	Business records and website information must remain available after deletion, corruption, migration failure, or service disruption.	Partially implemented	Business records are backed up and have been restored successfully; website files and migration materials are available.	Complete and document the website migration and restoration test; retain recovery instructions and test results.	Backup records; restoration results; website files; migration documentation; website recovery-test evidence	Richard Vincent	R-05, R-08

The Phone Boss ULTD — SoA Implementation Plan

Target dates are intentionally left for the owner to schedule. A control is not complete until suitable evidence confirms implementation and operation.

Control	Priority	Improvement action	Owner	Target date	Status	Expected evidence	Completion notes	Verification result
A.5.9	Open	Create a consolidated inventory covering customer devices in custody, business devices, critical accounts, cloud services, websites, domains, ownership, location, purpose, and status.	Richard Vincent	To be scheduled	Planned	Asset register; repair-device log; critical-account list; cloud-service inventory; review record		
A.5.15	Open	Document access-control rules, maintain an account inventory, conduct periodic reviews, and establish approval and removal steps before adding workers or contractors.	Richard Vincent	To be scheduled	Planned	Access-control policy; account inventory; access-review record; account settings; onboarding and offboarding records		
A.5.19	Open	Create a supplier register and document data access, dependency, security expectations, review frequency, recovery, and exit arrangements.	Richard Vincent	To be scheduled	Planned	Supplier register; agreements; provider security information; MFA evidence; supplier reviews; insurance documentation		
A.5.24	Open	Document and test an incident-response procedure covering identification, containment, evidence preservation, communication, recovery, and lessons learned.	Richard Vincent	To be scheduled	Planned	Incident-response procedure; incident log; notification contacts; communication templates; tabletop results		
A.5.30	Open	Document continuity arrangements for owner unavailability, provider outages, website disruption, restoration, and customer communication; complete recovery testing.	Richard Vincent	To be scheduled	Planned	Restoration record; continuity plan; recovery instructions; emergency contacts; website test; continuity exercise		
A.5.34	Open	Document privacy, retention, secure deletion, customer-request, and suspected-breach procedures.	Richard Vincent	To be scheduled	Planned	Privacy notice; information inventory; retention schedule; deletion records; passcode-destruction confirmation; incident records		
A.7.9	Open	Document transportation, custody, overnight storage, loss reporting, and return procedures; consistently retain custody evidence.	Richard Vincent	To be scheduled	Planned	Customer intake form; custody record; overnight-device log; return confirmation; storage-control evidence		
A.8.1	Evidence collection	Collect operating evidence and migrate business activity to dedicated secured devices as an improvement.	Richard Vincent	To be scheduled	Collect evidence	Device inventory; encryption status; update status; endpoint-protection status; lock and remote-wipe settings; backup evidence		
A.8.5	Open	Verify password uniqueness, recovery methods, active sessions, connected integrations, and available phishing-resistant authentication.	Richard Vincent	To be scheduled	Planned	MFA configuration; password-manager review; recovery settings; active-session review; integration inventory		
A.8.13	Open	Complete and document the website migration and restoration test; retain recovery instructions and test results.	Richard Vincent	To be scheduled	Planned	Backup records; restoration results; website files; migration documentation; website recovery-test evidence		

Statement of Applicability — Method and Scope

Document classification: Internal business record. Owner: Richard Vincent. Review date: To be scheduled.

Purpose

This starter records why 10 priority Annex A controls apply to The Phone Boss ULTD, their current implementation status, identified gaps, evidence expectations, ownership, and risk-register traceability.

It supports practical ISMS development and portfolio demonstration. It does not represent a complete certification SoA or claim conformity or certification.

A certification-ready SoA would consider all 93 Annex A reference controls plus any additional controls selected through risk treatment.

Required SoA fields

Field	Purpose		Status	Meaning		
Control	Identifies the Annex A reference control.		Implemented	Control exists and sufficient evidence supports implementation.		
Applicable	States whether the control is necessary.		Implemented — evidence pending	Control is stated to exist, but the evidence pack is not yet complete.		
Justification	Explains why the control is included or excluded.		Partially implemented	Some required practices exist, but material gaps remain.		
Status	States the current implementation position.		Planned	Control is selected but implementation has not begun or is not operational.		
Implementation	Describes what currently exists.		Not applicable	Control is unnecessary and the exclusion has a documented, risk-based justification.		
Evidence	Identifies records that support verification.					
Risk link	Shows traceability to the risk assessment.					

Review and approval

Review this starter after significant business, technology, supplier, staffing, legal, or risk changes.

Update implementation statuses only after reviewing evidence. Planned actions do not prove implementation.

Document any future exclusions with a clear business and risk justification.

Richard Vincent, as business owner, approves control selection and accepts residual risk.

Source: ISO/IEC 27001:2022 official overview — <https://www.iso.org/standard/27001>